

DIAMOND HANDS HOLDING INC.

TO: Jake Bulim, Evan Battaglia, John Smith, Steve Smith, Katie Tylerr
FROM: Chander Blount, Ethan Byrd, Hatice Bulut
SUBJECT: Policy Program Design – Information Security
DATE: December 02, 2025

Dear Executives and Stakeholders,

The purpose of this memorandum is to inform executive leadership of the completed redesign of Diamond Hands Holdings Inc.'s Cybersecurity Program Policy (CPP) and the associated governance improvements proposed in the Security Policy Design report. The revised CPP establishes a unified, enterprise-wide framework aligned with NIST CSF, NIST SP 800-53, and ISO/IEC 27001, ensuring that DHHI's security posture is consistent, measurable, and compliant with regulatory requirements.

The report identifies significant weaknesses in the current decentralized policy environment, including inconsistent enforcement, outdated procedures, and lack of policy lifecycle controls. To address these gaps, the team developed a comprehensive Improvement Program composed of interlinked initiatives, including the formation of a Policy Governance Committee, deployment of a centralized policy management platform, creation of a standardized ISSP lifecycle, and implementation of structured training and awareness programs.

These coordinated initiatives will move DHHI toward a mature, sustainable cybersecurity governance structure that strengthens risk management, enhances operational resilience, and supports long-term organizational growth. Executive support will be critical in approving the updated CPP, resourcing the implementation plan, and reinforcing policy accountability across all business units.

Please review the enclosed report for the detailed recommendations, budget projections, and policy drafts prepared for your approval.

Sincerely,
Chandler Blount, Ethan Byrd, Hatice Bulut
Cybersecurity Process Consultants

Information Security Policy Program Design and Enterprise Information Security Policy

Chandler Blount, Ethan Byrd, Hatice Bulut

December 02, 2025

Table of Contents

Executive Summary	1
Problem Statement	1
Project Scope.....	1
Current Policy Environment	2
Targeted State for Policy.....	3
Approaches to Improve Policy	4
Updated Cybersecurity Program Policy (CPP).....	7
ISSP Development Plan	8
ISSP Policy Example.....	9
3-Year Cost	11
Discussion.....	11
Conclusion.....	12
AI/LLM Usage Statement	Error! Bookmark not defined.

Executive Summary

The report details the current policy environment, outlines the desired target state for DHHI's cybersecurity governance, and provides an actionable improvement program composed of interlinked initiatives. It introduces a complete Cybersecurity Program Policy (CPP), modeled after the Enterprise Information Security Policy (EISP), which defines DHHI's overarching information security principles, management responsibilities, and compliance expectations. Additionally, a sample Issue-Specific Security Policy (ISSP), the Acceptable Use Policy, is provided to demonstrate how targeted operational guidance will be derived from the CPP. The proposed three-year budget forecast supports sustainable policy implementation, staff training, and continuous improvement cycles. Collectively, this program is designed to enhance DHHI's cybersecurity maturity, ensure legal and regulatory compliance, and foster a culture of security awareness and shared responsibility.

Problem Statement

Diamond Hands Holdings Inc. currently operates without a centralized or formally governed cybersecurity policy framework, resulting in inconsistent security practices across departments. Existing documentation lacks standardization and fails to define accountability for policy enforcement or exception management. These deficiencies increase the organization's exposure to operational, regulatory, and reputational risks. Without a unified Cybersecurity Program Policy (CPP) to guide information handling, user conduct, and compliance expectations, DHHI faces challenges in ensuring data protection, maintaining business continuity, and meeting evolving industry standards. The absence of structured review and update processes also prevents continuous alignment with emerging threats and new legal requirements such as the General Data Protection Regulation (GDPR) and state-level privacy laws.

Project Scope

This report applies to all divisions, departments, and subsidiaries operating under Diamond Hands Holdings Inc. It encompasses all information systems, technologies, and personnel that interact with DHHI's data assets, including employees, contractors, and third-party service providers. The Cybersecurity Program Policy (CPP) and associated Issue-Specific Security Policies (ISSPs) are intended to provide a unified governance structure that ensures consistent information security management throughout the organization. The scope of this policy does not extend to external business partners or independent vendors except where contractual agreements explicitly require compliance with DHHI security standards.

This report is directed at senior executives, department heads, and compliance managers responsible for overseeing risk and governance functions within DHHI. The policies outlined

herein are designed to provide both strategic direction and operational clarity, enabling leaders to make informed decisions regarding resource allocation, enforcement priorities, and policy lifecycle management. Limitations include the assumption that existing technological infrastructure can support the proposed governance model and that staff participation in policy adoption and training will be fully supported by executive leadership.

Current Policy Environment

Diamond Hands Holdings Inc. (DHHI) currently operates in a moderately developed cybersecurity environment that lacks a unified and enforceable policy management framework. While some isolated procedural documents and departmental standards exist, there is no formalized Cybersecurity Program Policy (CPP) or overarching governance structure to ensure consistent implementation and monitoring of information security practices. The absence of centralized policy ownership has resulted in fragmented oversight, leaving departments to define and interpret their own procedures, often without alignment to enterprise-level objectives or regulatory requirements.

At present, cybersecurity responsibilities within DHHI are distributed across IT, compliance, and risk management functions without a clearly defined hierarchy of authority. The Chief Information Security Officer (CISO), Evan Battaglia, provides general oversight of security initiatives, yet there are limited formal mechanisms for periodic review, enforcement, or reporting to the executive board. This decentralized approach creates gaps in accountability, inconsistent documentation, and a lack of standardized enforcement mechanisms. Consequently, the organization's ability to demonstrate due diligence during audits or incidents is significantly constrained.

Moreover, there is no documented process for policy creation, review, or retirement, which has led to outdated procedures remaining in circulation. Key cybersecurity domains such as access control, data classification, incident response, and acceptable use are not supported by current written policies. Similarly, DHHI lacks a version-controlled repository or content management system for its information security policies, preventing consistent communication and employee access.

From a compliance standpoint, DHHI has exposure to multiple industry and regulatory requirements that necessitate formal policy governance. The company's operations, particularly its financial and data analytics divisions, handle sensitive personal information and intellectual property that may fall under the scope of federal and state privacy laws such as the Gramm-Leach-Bliley Act (GLBA), Health Insurance Portability and Accountability Act (HIPAA) (for potential healthcare-related data), and state-level data protection regulations. Additionally, because DHHI handles customer data in a digital environment, the organization must adhere to best practices established by the NIST Cybersecurity Framework (CSF) and ISO/IEC 27001 standards for information security management systems. However, current documentation does not demonstrate formal alignment with these standards, and policy-related compliance reporting is performed on an ad hoc basis.

The organization's awareness and training programs are also underdeveloped. While new employees receive general IT onboarding, there is no recurring cybersecurity awareness curriculum tied to policy education. As a result, employee behavior varies widely, with some teams applying strong password management and access controls while others rely on informal communication channels for sharing credentials or sensitive project files.

Furthermore, incident response and exception handling procedures remain reactive. Security events are typically escalated via email or informal communication rather than through a standardized incident management workflow. The lack of an official Policy Exception and Enforcement Framework increases the risk that security exceptions go undocumented or unapproved, potentially violating compliance mandates.

Collectively, these weaknesses illustrate the urgent need for a formalized, enterprise-level cybersecurity governance structure. A properly designed and implemented Cybersecurity Program Policy (CPP) will provide a single authoritative framework for managing all subordinate Issue-Specific Security Policies (ISSPs), define clear ownership and accountability, and ensure ongoing compliance with regulatory and operational standards. The next section of this report—Targeted Policy State—defines the future vision for a mature and sustainable cybersecurity policy environment at DHHI.

Targeted State for Policy

The targeted policy state for Diamond Hands Holdings Inc. (DHHI) envisions a unified, enterprise-level cybersecurity governance framework supported by a comprehensive Cybersecurity Program Policy (CPP). This policy will define the overarching principles, responsibilities, and compliance expectations that guide all subordinate Issue-Specific Security Policies (ISSPs). The goal is to achieve consistency, accountability, and alignment between DHHI's cybersecurity operations and its strategic objectives, while maintaining compliance with industry standards such as NIST CSF, NIST SP 800-53, and ISO/IEC 27001.

A centralized Policy Governance Committee (PGC), chaired by the Chief Information Security Officer (CISO), will be established to oversee the policy lifecycle — from drafting and review to approval and retirement. The committee will include representatives from Legal, IT, Human Resources, and Risk Management, ensuring balanced decision-making and compliance with both internal and regulatory requirements. Each policy will include clear ownership, approval history, and review schedules, reinforcing accountability.

DHHI will implement a standardized policy management lifecycle comprising five stages:

1. Drafting and Stakeholder Consultation
2. Legal and Compliance Review
3. CISO and Executive Approval
4. Organization-wide Communication and Training
5. Annual Review and Continuous Improvement

To enhance adoption and compliance, policies will be distributed via an automated awareness platform requiring employee acknowledgment. Exceptions will be managed through a formalized approval workflow involving documentation, justification, and risk acceptance by both policy owners and the CISO.

The target state also prioritizes security awareness and culture-building. Regular training, quarterly refreshers, and executive briefings will ensure that personnel understand both the rational and operational requirements behind each policy. The CPP will directly link policies to measurable performance indicators, including training completion rates, policy violation trends, and audit compliance scores.

By implementing this model, DHHI will move from a fragmented policy environment to a cohesive, metrics-driven cybersecurity governance program. The result will be a transparent, enforceable, and continuously improving security posture that supports regulatory compliance, reduces operational risk, and builds organizational resilience.

Approaches to Improve Policy

This Improvement Program establishes a coordinated set of initiatives designed to move Diamond Hands Holdings Inc. (DHHI) from its current fragmented cybersecurity governance posture to the unified, mature policy environment described in the Targeted Policy State. Each initiative is structured as a project with defined objectives, timelines, resources, and dependencies.

Initiative 1: Establish a Centralized Policy Governance Committee (PGC)

Objective: Create an enterprise-level authority to oversee policy creation, review, retirement, and compliance.

Timeline: Month 1–2

Activities:

- Assigning CISO as Chair
- Appoint representatives from Legal, IT, HR, and Risk
- Approve policy templates and lifecycle standards

Dependencies: Executive approval

Outcome: Unified oversight structure that governs all cybersecurity policies.

Initiative 2: Deploy the Policy Management Platform

Objective: Implement an enterprise platform for centralized distribution, version control, acknowledgements, and audits.

Timeline: Month 2–4

Activities:

- Select platform (e.g., OneTrust, SecureFrame, or equivalent)
- Configure approval workflows
- Migrate legacy documents

Dependencies: PGC formation

Outcome: Automated, trackable, enterprise-wide policy governance.

Initiative 3: Develop and Approve the Updated Cybersecurity Program Policy (CPP)

Objective: Publish a revised, authoritative CPP to serve as the foundation for all ISSPs.

Timeline: Month 3–6

Activities:

- Draft updated CPP
- Perform HR/Legal/Compliance review
- Submit to Executive Committee

Dependencies: Policy platform configuration

Outcome: A fully modernized top-level policy establishing roles, responsibilities, and governance.

Initiative 4: ISSP Lifecycle Implementation (Access Control, AUP, Incident Response, etc.)

Objective: Build a repeatable lifecycle and publish prioritized Issue-Specific Security Policies.

Timeline: Month 4–18

Activities:

- Prioritize policies driven by risk assessment
- Draft using standardized ISSP template
- Conduct approvals, distribution, and training

Dependencies: CPP approval

Outcome: Complete and consistent ISSP ecosystem aligned with NIST CSF and SP 800-53 controls.

Initiative 5: Policy Training & Awareness Program

Objective: Ensure all personnel understand and comply with new policies.

Timeline: Month 6–24

Activities:

- Develop onboarding modules and annual refreshers
- Integrate policy quizzes and digital acknowledgments
- Build security culture campaigns

Dependencies: CPP and initial ISSPs

Outcome: Workforce-wide alignment with security responsibilities and reduced violation trends.

Initiative 6: Integration Testing of Policies with New Assets (Including Pen Testing)

Objective: Validate that newly deployed or modified assets do not contradict, weaken, or bypass policy requirements.

Timeline: Continuous (quarterly cycles)

Activities:

- Conduct security architecture reviews for new assets
- Perform targeted penetration testing on newly introduced systems
- Update policies based on discovered gaps

Dependencies: ISSP rollout

Outcome: Policies stay operationally relevant and security controls function as intended.

Initiative 7: Annual Policy Audit and Governance Review

Objective: Measure compliance, effectiveness, and improvement areas.

Timeline: Annual

Activities:

- Internal audits using audit checklist
- External review every three years
- Update documents based on audit findings

Outcome: Continuous improvement and regulatory alignment.

Updated Cybersecurity Program Policy (CPP)

The Cybersecurity Program Policy establishes the governance, responsibilities, and strategic direction necessary to protect Diamond Hands Holdings Inc.'s information assets. It serves as the primary enterprise-level security document from which all subordinate Issue-Specific Security Policies (ISSPs) derive authority.

Scope:

The CPP applies to all organizational units, employees, contractors, and third parties who access or manage DHHI information systems.

Policy Framework:

DHHI adopts a governance model aligned with:

- **NIST Cybersecurity Framework (CSF)**
- **NIST SP 800-53 Security Controls**
- **ISO/IEC 27001 Information Security Management System (ISMS)**

These frameworks drive DHHI's control selection, risk management, and compliance practices.

Governance & Roles

- **CISO:** Leads cybersecurity governance; chair of PGC.
- **Policy Governance Committee (PGC):** Responsible for drafting, reviewing, updating, and approving policies.
- **Executive Leadership:** Provides final approval and funding resources.
- **Managers:** Enforce policies within business units.
- **Employees/Contractors:** Follow all cybersecurity policies and participate in mandatory training.

Policy Lifecycle

1. Creation and Review

Policies must be created using the standard template and reviewed annually or triggered by regulatory or technological changes.

2. Approval

All cybersecurity policies require CISO approval and final sign-off from Executive Leadership.

3. Distribution & Awareness

All employees must acknowledge receipt of policies within the Policy Management Platform. Training is required for all high-impact policies.

4. Exception Management

Policy exceptions require documented justification and written approval from the CISO. Exceptions expire annually unless renewed.

5. Maintenance & Retirement

Policies are retired only when replaced; archival copies must be retained for seven years.

Compliance & Enforcement

Failure to comply with policies may result in disciplinary action up to termination, contractual penalties, or legal consequences.

Policy violations must be documented, investigated, and remediated according to the Incident Response Policy.

ISSP Development Plan

A structured, repeatable development process is required to ensure that all Issue Specific Security Policies (ISSPs) at the organization are consistent, legally compliant, and aligned with the cybersecurity services defined in the Group Security Services Plan. The ISSP process will follow a six-step lifecycle that defines how policies are initiated, created, reviewed, approved, distribution, maintained, and retired.

1. Identification and Prioritization of ISSP

ISSP topics will be identified through risk assessments, compliance requirements, operational requirements, and security service capabilities. Areas like access control, acceptable use, incident response, vulnerability management, and data protection will be prioritized. Each ISSP request will be logged, assigned to an owner, and evaluated for legal, regulatory compliance.

2. Drafting and Initial Review

The policy owner, in partnership with the Cybersecurity Manager, will prepare an initial draft following the company's standardized ISSP template. Drafting must follow required elements: purpose, scope, policy statements, responsibilities, procedures or standards, enforcement, and references. The draft is then reviewed by IT, HR, Compliance, and Legal to ensure operational feasibility and regulatory alignment.

3. Executive Approval

After the content of the policy is reviewed, policies will be submitted to the CIO or designated security leadership team for formal approval. Executive approval ensures visibility, organizational support, and accountability for policy enforcement.

4. Distribution and Training

Approved policies will be distributed through the company's intranet, email announcements, and onboarding systems. Mandatory training modules will be distributed alongside important ISSPs (e.g., Acceptable Use, Access Control, Incident Response). Employees must acknowledge they received the training using an electronic signature system that maintains audit logs.

5. Validation and Enforcement

Managers and system owners will be responsible for verifying compliance with relevant ISSPs. Violations will align with the company's enforcement policy and be coordinated with HR.

6. Maintenance and Retirement

Each ISSP will undergo a formal review every 12 months, or earlier if needed by regulatory updates, incidents, technology changes, or customer requirements. Policy retirement will occur only after a replacement policy has been approved.

ISSP Policy Example

1. Purpose

The purpose of this policy is to establish the requirements for granting, managing, monitoring, and revoking access to organizational information systems. The policy ensures that only authorized individuals have access appropriate to their job responsibilities, and that access is promptly revoked when no longer required.

2. Scope

This policy applies to all employees, contractors, consultants, temporary workers, and third-party service providers who access company information systems, applications, networks, or data resources.

3. Policy Statements

3.1 Least Privilege and Role-Based Control

Access will be provisioned using the principle of least privilege. Users will receive only the minimum access necessary to perform their duties. Role-Based Access Control (RBAC) shall be used for all enterprise applications and systems.

3.2 Authentication and MFA Requirements

All users must authenticate using company-approved identity systems. Multi-factor authentication (MFA) is required for all cloud services, administrative accounts, VPN access, and systems storing restricted or confidential data.

3.3 Provisioning and De-Provisioning

New access must be requested through the official access request workflow, approved by supervisors, and documented in the IAM system. Access must be revoked within 24 hours of employee separation or role change. Emergency access will require time-bound approval by the CIO.

3.4 Privileged Access Management (PAM)

Administrative and highly sensitive accounts will be managed using the organization's PAM solution. Privileged users must check out credentials, and all privileged activity must be logged, monitored, and subject to periodic review.

3.5 Monitoring and Logging

All access events, including authentication attempts, privilege escalations, and failed logins, must be logged and stored in the SIEM for continuous monitoring. Anomalous access behavior will trigger alerts handled by the SOC.

4. Responsibilities

Cybersecurity Manager: Ensures implementation of IAM, RBAC, MFA, and monitoring controls.

Supervisors: Approve access requests and validate user access during quarterly reviews.

IT Operations: Implements provisioning and de-provisioning and supports access audits.

Employees: Maintain secure authentication practices and report suspicious activity.

5. Enforcement

Violations of this policy may result in disciplinary action up to and including termination, civil penalties, or criminal charges. Unauthorized access attempts may trigger incident response procedures.

6. Review and Maintenance

This policy will be reviewed annually or upon any significant change in technology, business operations, or regulatory requirements.

3-Year Cost

<u>Service</u>	<u>Year 1</u>	<u>Year 2</u>	<u>Year 3</u>	<u>Description</u>
Policy Management Platform	\$18,000	\$18,000	\$18,000	Software for policy distribution, versioning, acknowledgements
Staff Training	\$12,000	\$15,000	\$18,000	Annual training modules, onboarding, refreshers
Legal/Compliance Review	\$10,000	\$12,000	\$12,000	External legal review of key policies, contractual requirements
Policy Development Service	\$40,000	\$42,000	\$44,000	Staff time for drafting, managing, and maintaining policies
Third-party Risk Assessment	\$8,000	\$10,000	\$10,000	Ensures alignment of vendor practices with policy requirements
Policy Audits	\$9,000	\$9,000	\$9,000	Internal/external audits validating policy compliance

Discussion

The recommendations presented throughout this document include several optional elements that decision-makers may tailor based on organizational priorities, budget limitations, or desired maturity level.

For example, the selection of a Policy Management Platform, which is strongly recommended, is still flexible depending on available budget and IT integration requirements. Likewise, the number and depth of annual policy audits may vary depending on risk tolerance and regulatory pressure. Some policies, such as Privileged Access Management or continuous penetration testing, represent optional enhancements for organizations seeking higher maturity rather than minimal compliance.

Similarly, DHHI may choose between conducting internal training development or outsourcing cybersecurity training modules. There is also flexibility in how frequently committees meet, the extent of automation in policy workflows, and how aggressively DHHI wants to schedule the ISSP rollout.

These optional decisions allow leadership to determine the appropriate balance between cost, operational impact, and long-term cybersecurity maturity. The Improvement Program is designed so that each initiative stands on its own but also strengthens the others when fully implemented.

Conclusion

This report establishes a complete framework for modernizing Diamond Hands Holdings Inc.'s cybersecurity governance environment. Through a comprehensive analysis of the current policy landscape, identification of critical gaps, and alignment with industry standards, it provides a structured path toward a unified, resilient, and enforceable policy ecosystem. The Improvement Program, along with the updated Cybersecurity Program Policy, and ISSP development plan collectively offer a scalable model that promotes accountability, strengthens regulatory compliance, and enhances organizational security posture.

By adopting the recommendations in this report, DHHI positions itself to transition from fragmented procedures to a mature cybersecurity governance program grounded in continuous improvement. The organization will improve its ability to protect sensitive data, respond to threats, and maintain operational resilience in an evolving risk landscape. This program ultimately builds the foundation for a stronger security culture, clearer decision-making, and a long-term reduction in organizational risk.